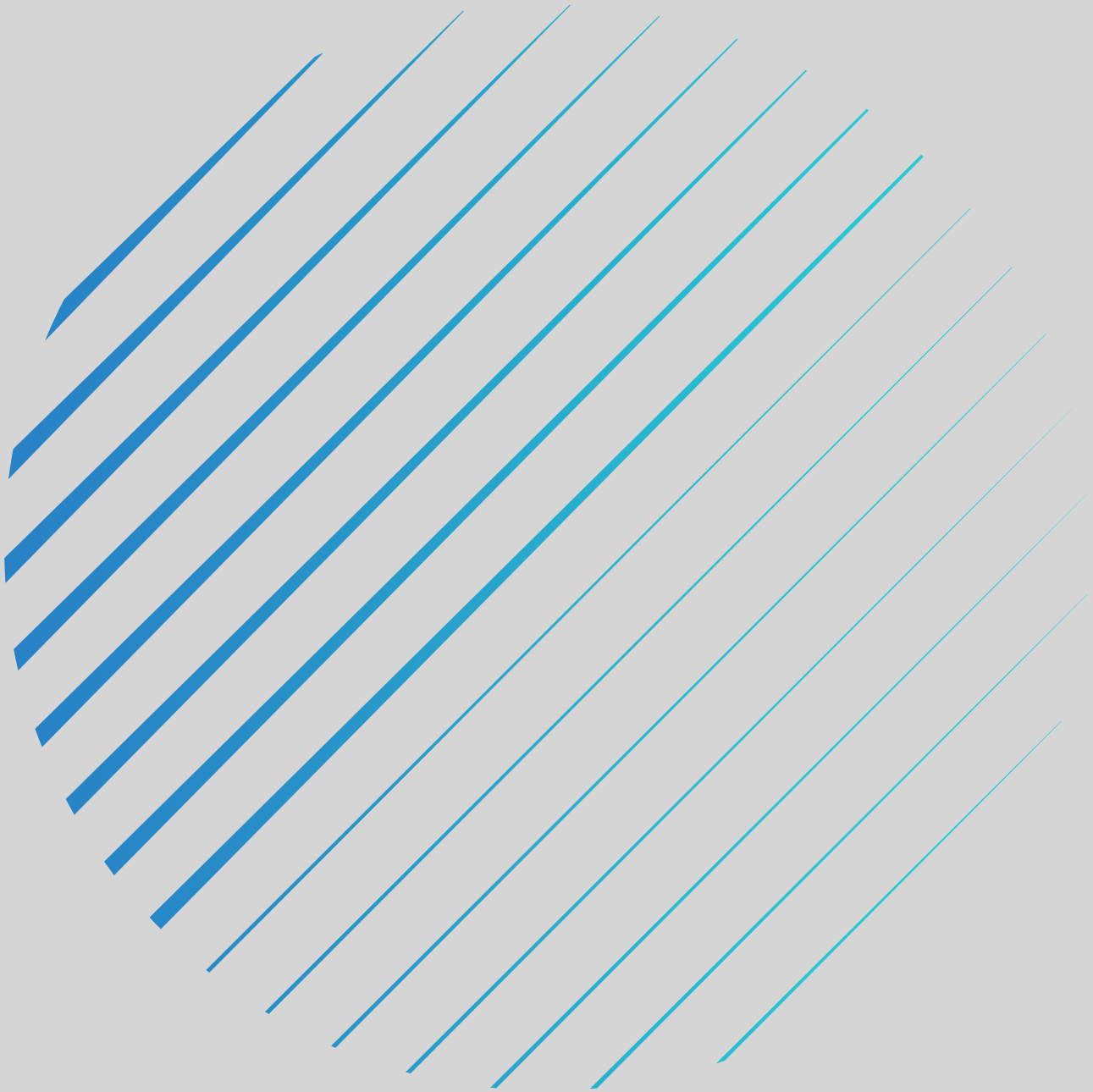
Ejercicio1-Diccionario



14/09/2026
DAW2

Santiago González Vicente

Tabla de contenido

Ejercicio1-Diccionario 1
Amenazas y vulnerabilidades informáticas 3
Principios de CIA 3
Diferencias entre Amenazas y Vulnerabilidades 5
Clasificación de amenazas: 5
Técnicas: 6
Ataques a la red: 7
Clasificación de vulnerabilidades 10
Relación entre amenazas y vulnerabilidades 11
Evaluación de las consecuencias de las amenazas y vulnerabilidades. 13
Señales y síntomas de amenazas y vulnerabilidades activas. 14
Medidas de protección básicas. 15
Importancia de las configuraciones seguras en la ciberseguridad. 15
Gestión de contraseñas robustas 16
Control de accesos y permisos. 17
Herramientas para gestionar actualizaciones y parches de seguridad. 18
Análisis de los incidentes de seguridad. 18
Herramientas y tecnologías de aplicación. 18
Enlaces 18

Amenazas y vulnerabilidades informáticas

Las vulnerabilidades y amenazas informáticas son un riesgo para los sistemas y la información de la empresa, sobre todo en el entorno actual, altamente digitalizado y dependiente de los servicios TI.



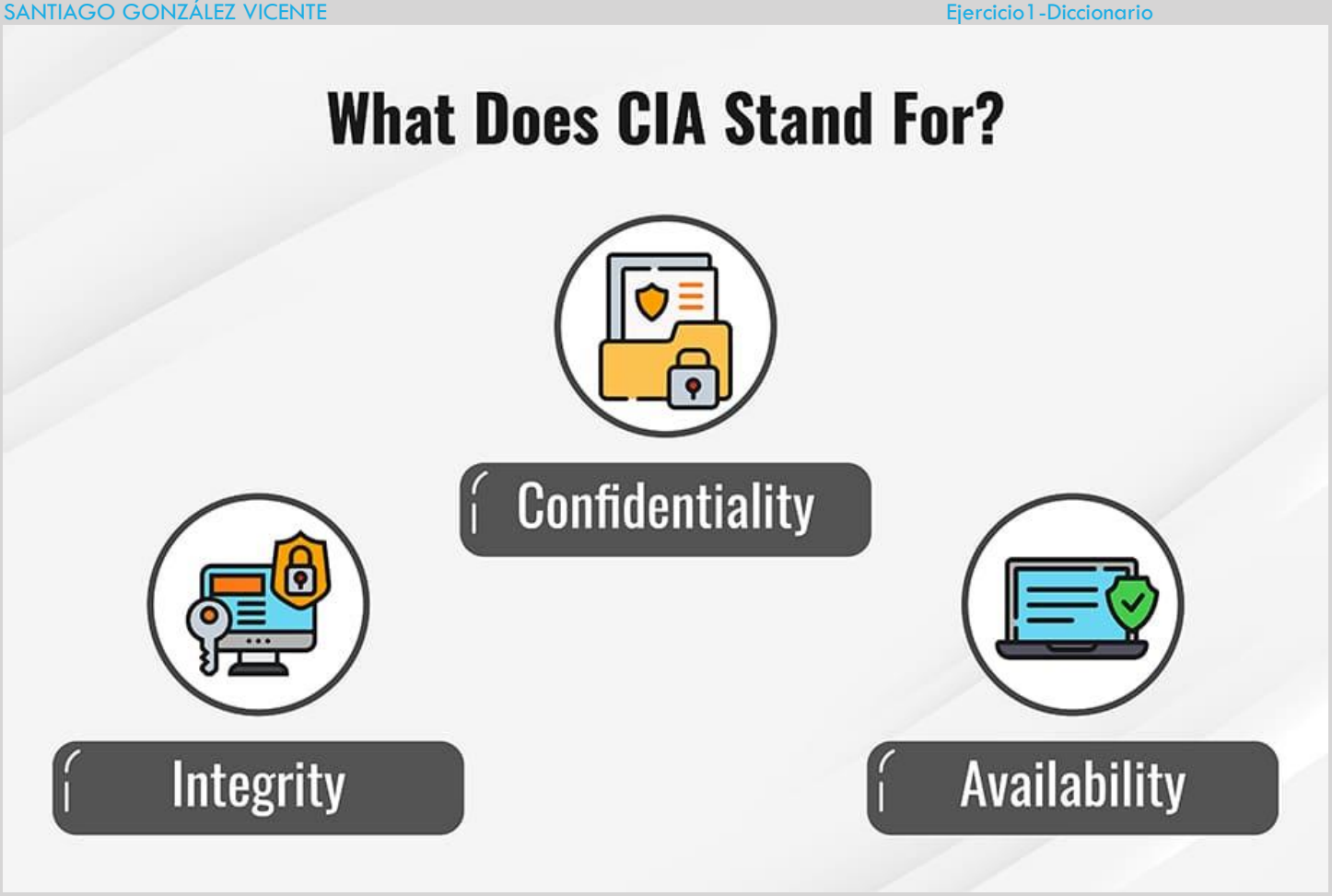
Para poder tomar las medidas adecuadas para proteger los recursos tecnológicos y la información de la empresa es necesario conocer cuáles son las principales amenazas y vulnerabilidades que ponen en riesgo la seguridad de la empresa en la red.

Principios de CIA

Las tres letras de la "tríada de la CID" significan confidencialidad, integridad y disponibilidad. La tríada de la CID es un modelo común que constituye la base para el desarrollo de sistemas de seguridad. Se utilizan para encontrar vulnerabilidades y métodos para crear soluciones.

La confidencialidad, integridad y disponibilidad de la información es crucial para la operación de un negocio, y la tríada CIA segmenta estas tres ideas en puntos focales separados. Esta diferenciación es útil porque ayuda a guiar a los equipos de seguridad a medida que identifican las diferentes formas en que pueden abordar cada inquietud.

Idealmente, cuando se cumplen los tres estándares, el perfil de seguridad de la organización es más sólido y está mejor equipado para manejar incidentes de amenazas.



1. **Confidencialidad**

La confidencialidad implica los esfuerzos de una organización para garantizar que los datos se mantengan en secreto o privados. Para lograrlo, el acceso a la información debe controlarse para evitar el intercambio no autorizado de datos, ya sea intencional o accidental y asegurar la integridad de la información. Un componente clave para mantener la confidencialidad es asegurarse de que las personas sin la autorización adecuada no tengan acceso a activos importantes para su negocio. Por el contrario, un sistema eficaz también garantiza que aquellos que necesitan tener acceso tengan los privilegios necesarios.

2. **Integridad**

La integridad implica asegurarse de que sus datos sean confiables y estén libres de alteraciones. La integridad de sus datos se mantiene solo si los datos son auténticos, precisos y confiables.

A menudo, comprometer la integridad se hace intencionalmente. Un atacante puede omitir un sistema de detección de intrusos (IDS, por sus siglas in inglés), cambiar las configuraciones de archivos para permitir el acceso no autorizado o alterar los registros que mantiene el sistema para ocultar el ataque y poner en riesgo la seguridad de la información. La integridad también puede violarse por accidente. Alguien puede ingresar accidentalmente el código incorrecto o cometer otro tipo de error por descuido. Además, si las políticas, protecciones y procedimientos de seguridad de la empresa son inadecuados, se puede violar la integridad sin que ninguna persona de la organización tenga la culpa.

3. **Disponibilidad**

Incluso si los datos se mantienen confidenciales y se mantiene su integridad, a menudo son inútiles, a menos que estén disponibles para aquellos en la organización y los clientes a los que prestan servicios. Esto significa que los sistemas, las redes y las aplicaciones deben funcionar como deberían y cuándo deberían. Además, las personas con acceso a información específica deben ser capaces de consumirla cuando lo necesitan, y llegar a los datos no debería tomar una cantidad de tiempo excesiva.

Diferencias entre Amenazas y Vulnerabilidades

1. Amenazas

Una **amenaza** es cualquier acción, agente o circunstancia que puede causar daños a un sistema informático, robar información o comprometer la seguridad de los datos.

Tipos de amenazas:

- **Malware:** Programas maliciosos, como virus, troyanos y ransomware.
- **Phishing:** Engaños para obtener contraseñas o datos personales.
- **Ataques de hackers:** Accesos no autorizados a sistemas informáticos.
- **Amenazas físicas:** Robo de equipos, incendios o daños en los dispositivos.
- **Errores humanos:** Acciones involuntarias que pueden poner en riesgo la información.

2. Vulnerabilidades

Una **vulnerabilidad** es una debilidad o fallo en un sistema informático que puede ser aprovechado por una amenaza para comprometer su seguridad.

Tipos de vulnerabilidades:

- **De software:** Errores en programas o sistemas operativos.
- **De configuración:** Configuraciones inseguras, como permisos excesivos.
- **De contraseñas:** Uso de contraseñas débiles o fáciles de adivinar.
- **De red:** Redes mal protegidas o sin cifrado adecuado.
- **Humanas:** Falta de formación en seguridad o desconocimiento de los riesgos.

3. Diferencia principal

La **amenaza** es el peligro que puede causar un daño, mientras que la **vulnerabilidad** es la debilidad que ese peligro puede aprovechar.

Ejemplo: Un hacker (amenaza) aprovecha una contraseña débil (vulnerabilidad) para acceder a un ordenador y robar información.

Clasificación de amenazas:

-Tipos de malware

-**Virus.** Los virus informáticos son un software que se instalan en un dispositivo con el objetivo de ocasionar problemas en su funcionamiento. Para que un virus infecte un sistema es necesaria la intervención de un usuario (intencionada o inintencionadamente).

-**Gusanos.** Es uno de los malware más comunes que infectan los equipos y sistemas de una empresa, ya que no requieren de la intervención del usuario ni de la modificación de algún archivo para poder infectar un equipo. El objetivo de los gusanos es el de replicarse e infectar el mayor número de dispositivos posibles utilizando la red para ello. Son una amenaza para las redes empresariales, porque un solo equipo infectado puede hacer que la red entera se vea afectada en un espacio corto de tiempo.

-**Troyanos.** Los troyanos son programas que se instalan en un equipo y pasan desapercibidos para el usuario. Su objetivo es el de ir abriendo puertas para que otro tipo de software malicioso se instale.

-**Ransomware.** El Ransomware se ha convertido en el malware más temido en la actualidad por las empresas. Consiste en encriptar toda la información de la empresa, impidiendo el acceso a los datos y los sistemas y se pide un rescate para poder liberar la información (normalmente en criptomonedas como bitcoins).

-**Keyloggers.** Se instalan a través de troyanos y se encargan de robar datos de acceso a plataformas web, sitios bancarios y similares.

-Técnicas de ingeniería social

En un contexto de ciberseguridad, la ingeniería social es el conjunto de tácticas utilizadas para manipular, influir o engañar a una víctima para que divulgue información sensible o realice acciones poco aconsejables para liberar información personal y financiera o ceder el control de un sistema informático.

La ingeniería social, una ciencia malévola, utiliza la manipulación psicológica, la persuasión y la explotación para engañar a los usuarios para que cometan errores de seguridad o cedan información sensible. Los ataques de ingeniería social se basan en la interacción humana y a menudo implican embaucar a las víctimas para que infrinjan los procedimientos normales de seguridad. Por ejemplo, los ataques de ingeniería social pueden ser muy eficaces porque se basan en la tendencia humana a confiar en los demás o a explorar la propia curiosidad sobre nuevas ofertas o información actuando como cebo.

Técnicas:

- **Phishing:** Con la ingeniería social, un atacante suele hacerse pasar por un ejecutivo corporativo para engañar a los usuarios para que envíen dinero a una cuenta bancaria en otro país.

- **Vishing y smishing**: Los atacantes usan mensajes de texto y software de cambio de voz para enviar mensajes de texto o llamar automáticamente a los usuarios. El mensaje promete regalos o servicios a cambio de un pago. Estos tipos de estafas se conocen como Vishing (voice phishing, en español phishing de voz) y smishing (phishing de SMS).

- **Fraude al CEO (director general):** Los usuarios suelen presentar una sensación de urgencia cuando un ejecutivo les solicita una acción específica, así que un atacante simulará ser el director general (CEO) u otro ejecutivo para dar una sensación de urgencia al empleado objetivo para que este ejecute una acción. Esto se conoce como fraude al CEO.

- **Baiting**: Es muy común que los atacantes prometan premios o dinero a cambio de un pequeño pago. La oferta suele ser demasiado buena como para ser cierta, y el pago suele ser para cubrir costes de envío u otros.

- **Pretextos**: Los atacantes pueden crear un pretexto falso para obtener información sensible o acceso a un sistema. Por ejemplo, un atacante podría hacerse pasar por un cajero de banco y ponerse en contacto con una persona objetivo para afirmar que ha habido actividad sospechosa en su cuenta y pedirle que comparta información delicada para confirmar su cuenta.

- **Tailgating o piggybacking**: Las corporaciones que usan escáneres de seguridad para bloquear el acceso no autorizado a las instalaciones. Los atacantes usan el Tailgating o piggybacking para engañar a los usuarios, de manera que estos usen sus tarjetas de acceso para darle al atacante acceso físico a las instalaciones.
- **Quid pro quo**: A un empleado descontento se le puede engañar para que revele información delicada a un atacante a cambio de dinero u otras promesas.

- **Abrevadero**: Esta forma de ataque de ingeniería social implica dirigirse a determinados grupos infectando sitios web que es probable que el grupo visite. Por ejemplo, un atacante podría infectar un sitio de noticias popular con malware con la intención de que los empleados de una determinada empresa visiten el sitio y descarguen inadvertidamente el malware.

Ataques a la red:

DoS y DDoS:

Un ataque de denegación de servicio (DoS) inunda un servidor con tráfico, lo que hace que un sitio web o recurso deje de estar disponible. Un ataque de denegación de servicio distribuido (DDoS) es un ataque de DoS que utiliza múltiples computadoras o máquinas para inundar un recurso específico. Ambos tipos de ataques cibernéticos sobrecargan el servidor o aplicación web con el objetivo de interrumpir los servicios.



A medida que el servidor es inundado con más paquetes de Protocolo de control de transmisión/Protocolo de datagrama de usuario (TCP/UDP) de los que puede procesar, puede bloquearse, los datos pueden dañarse y los recursos pueden desviarse o incluso agotarse hasta el punto de paralizar el sistema.

-**Diferencias**:

1. **Facilidad de detección/mitigación**: Dado que un ataque de DoS proviene de una única ubicación, es más fácil detectar su origen y cortar la conexión. De hecho, esto lo puede hacer un firewall eficaz. Por otro lado, un ataque de DDoS proviene de múltiples ubicaciones remotas, lo que oculta su origen.
2. **Velocidad de ataque**: Debido a que un ataque de DDoS proviene de múltiples ubicaciones, puede implementarse mucho más rápido que un ataque de DoS, que se origina desde una única ubicación. El aumento de la velocidad del ataque dificulta su detección, lo que implica un mayor daño o incluso un resultado catastrófico.
3. **Volumen de tráfico**: Un ataque de DDoS emplea múltiples máquinas remotas (zombies o bots), lo que significa que puede enviar cantidades mucho mayores de tráfico desde diversas ubicaciones de forma simultánea, lo que sobrecarga el servidor rápidamente y elude la detección.
4. **Modo de ejecución**: Un ataque de DDoS coordina múltiples hosts infectados con malware (bots), lo que crea una botnet administrada por un servidor de comando y control (CyC). Por el contrario, un ataque de DoS generalmente utiliza una secuencia de comandos o una herramienta para llevar a cabo el ataque desde una sola máquina.
5. **Rastreo del origen:** El uso de una botnet en un ataque de DDoS significa que rastrear el origen real es mucho más complicado que rastrear el origen de un ataque de DoS. ias:

Manin-the-Middle:

Un ataque de intermediario (MITM) es un ciberataque en el que un hacker roba información confidencial espiando las comunicaciones entre dos objetivos en línea, como un usuario y una aplicación web.

-**Funcionamiento**: Las vulnerabilidades en las redes, los navegadores web, las cuentas de correo electrónico, los comportamientos de los usuarios y los protocolos de seguridad son los puntos de partida de los ataques MITM. Los ciberdelincuentes explotan estas debilidades para insertarse entre los usuarios y las aplicaciones de confianza para poder controlar las comunicaciones e interceptar datos en tiempo real.

Los atacantes MITM a veces crean sus propias redes wifi públicas maliciosas para atraer a usuarios desprevenidos y recopilar sus datos personales.

Los atacantes de MITM también pueden crear sitios web falsos que parecen legítimos, pero que en realidad están recopilando datos críticos, como credenciales de inicio de sesión. Los hackers pueden usar esas credenciales para iniciar sesión en cuentas de usuario en sitios web auténticos. O podrían utilizar el sitio web falso para engañar a los usuarios para que realicen pagos o transfieran fondos.

-**Etapas:**

1. **Interceptación**

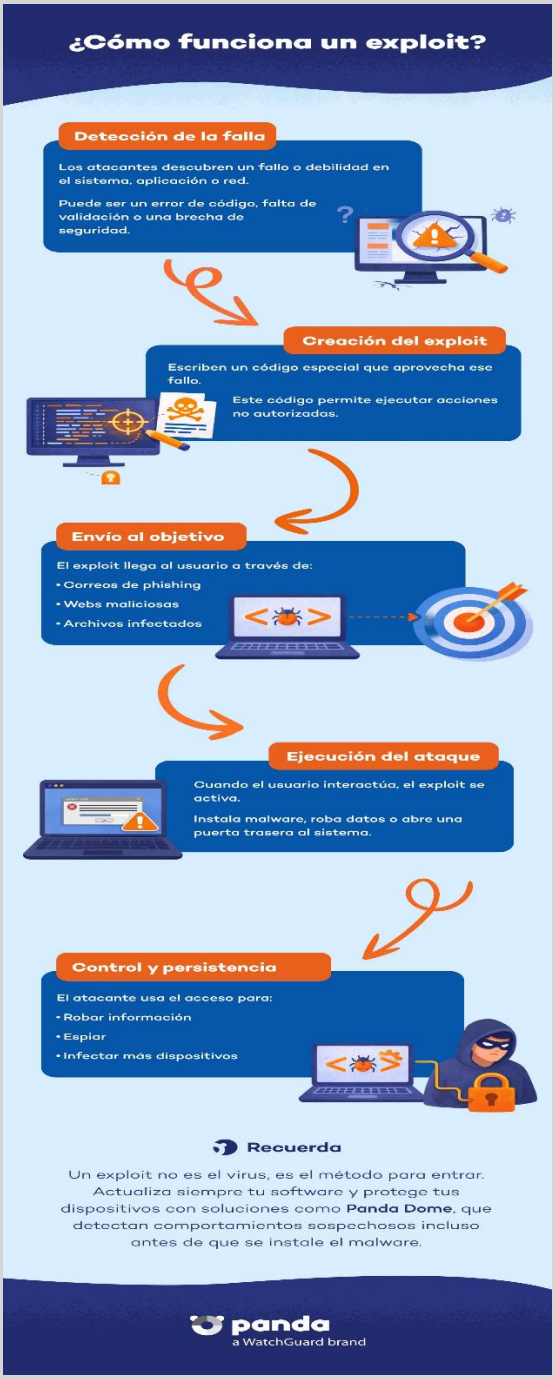
Para meterse en medio de dos objetivos que se comunican, como un usuario y una aplicación web, un atacante debe interceptar los datos que viajan entre los dos. A continuación, el atacante transmite esa información desviada entre los objetivos como si se tratara de comunicaciones normales para que las víctimas no sospechen nada.

2. **Descifrado**

Hoy en día, la mayoría de las comunicaciones por Internet están cifradas, por lo que es probable que cualquier dato que intercepte un atacante MITM deba descifrarse antes de que el atacante pueda utilizarlo. Los atacantes pueden descifrar datos robando claves de cifrado, ejecutando ataques de fuerza bruta o utilizando técnicas de ataque MITM especializadas (consulte la siguiente sección).

Exploits y ataques a aplicaciones web

Un Exploit es un fragmento de código o programa que aprovecha una vulnerabilidad o fallo en un sistema, aplicación, red o hardware. Suele emplearse para ejecutar software malicioso, obtener acceso no autorizado o comprometer un sistema.



Inyección SQL

El lenguaje de consulta estructurado (SQL) es el lenguaje estándar utilizado para consultar una base de datos. (Tenga en cuenta que una consulta realizada en un motor de búsqueda como Google o Bing es diferente).

Una inyección SQL (SQLi) es un tipo de ataque en el que los cibercriminales intentan explotar vulnerabilidades en el código de una aplicación insertando una consulta SQL en campos de entrada o formulario regulares, como un nombre de usuario o contraseña. Luego, la instrucción SQL se pasa a la base de datos SQL subyacente de la aplicación.

El daño puede ser grande. Un atacante con un buen conocimiento de SQL ingresa consultas en una aplicación basada en la web sin parámetros de validación de entrada implementados, luego accede fácilmente a los archivos de clientes de una empresa o a información financiera confidencial.

Cross-Site Scripting (XSS)

Funciona introduciendo cadenas de código malicioso ejecutable en estas funciones. Esto inyecta el código malicioso en el contenido del sitio web objetivo, haciéndolo parte del sitio web y permitiéndole así afectar a las víctimas que pueden visitar o ver ese sitio web. El código también puede presentarse como contenido transitorio que en realidad no forma parte del sitio web, pero que solo parece ser para el visitante. Esto hace que parezca que el sitio web está realmente comprometido por cibercriminales.

También pueden utilizar esta vulnerabilidad para tomar el control o comprometer directamente un sitio web, así como explotar otras vulnerabilidades existentes en el servidor o software del sitio web.

-**Funcionamiento:**
· Los ciberdelincuentes eligen su sitio web objetivo y analizan sus funciones vulnerables que aceptan la entrada del usuario. Algunos ejemplos son barras de búsqueda, formularios de inicio de sesión y cuadros de comentarios.

· Introducen código malicioso en la función que eligen. El código malicioso podría escribirse utilizando lenguaje de programación como HTML o JavaScript, entre otros.

· El código malicioso se inyecta en la página web que resulta de la función. A continuación, se convierte en parte de esa página web, lo que la pone en peligro.

· Dependiendo de cómo se inyecte, es posible que el contenido malicioso ni siquiera esté en la propia página web, sino como un elemento transitorio que solo parece formar parte del sitio web durante la instancia particular de la explotación.

· Los usuarios pueden convertirse en víctimas de la página web comprometida al ser vinculados a ella por los cibercriminales responsables o tropezarse con ella, dependiendo de la función que los culpables decidieron abusar.

Clasificación de vulnerabilidades

Sistemas

1. **Vulnerabilidad de desbordamiento de buffer**. Esta vulnerabilidad informática se produce cuando una aplicación es incapaz de controlar la cantidad de datos que se copian en buffer; si esa cantidad supera a su capacidad los bytes sobrantes se almacenan en otras zonas de la memoria y reescriben el contenido original. Como resultado, se puede aprovechar el problema para ejecutar un código que otorga al atacante privilegios como administrador.
2. **Vulnerabilidad de race condition.** La condición de carrera se refiere a lo que ocurre cuando varios procesos tienen acceso a un recurso compartido al mismo tiempo.
3. **Vulnerabilidades de format string bugs.** Se traduciría como errores de cadena de formato; el motivo de estos errores es aceptar sin validar la entrada de datos que proporciona el usuario. Es un error de diseño de las aplicaciones, un despiste en el momento de programar. Debido a esta vulnerabilidad se puede ejecutar un código arbitrario que facilite el robo de datos.
4. **Vulnerabilidades de denegación de servicio.** La denegación de servicio se usa con el propósito que los usuarios no puedan usar ese servicio. Lo consiguen mediante la pérdida de conectividad de la víctima del ataque por un consumo excesivo de ancho de banda de red o de recursos conectados al sistema.
5. **Vulnerabilidades de ventanas engañosas.** Esta es una vulnerabilidad muy popular y habitual. También se conoce como "Window spoofing" y permite al atacante mostrar ventanas y mensajes de notificación en nuestros ordenadores, con engaños sobre premios, sorteos y estafas similares.

Redes

1. **Vulnerabilidades de software**

Se producen por fallos en programas, aplicaciones o sistemas operativos. Incluyen errores de programación, configuraciones incorrectas o parches no aplicados que abren la puerta a exploits y malware.

2. **Vulnerabilidades de hardware**

Afectan directamente a dispositivos físicos como routers, switches o firewalls. Un firmware desactualizado o un dispositivo mal configurado puede exponer a toda la red.

3. **Vulnerabilidades humanas**

El factor humano sigue siendo una de las principales causas de incidentes de seguridad de red. Contraseñas débiles, errores en la configuración o caer en ataques de phishing facilitan el acceso a los ciberdelincuentes.

4. **Vulnerabilidades de protocolos de comunicación**

Algunos protocolos antiguos o inseguros, como Telnet o FTP sin cifrar, representan riesgos elevados si se utilizan en entornos críticos.

5. **Vulnerabilidades de configuración**

Incluso con sistemas seguros, una mala configuración, como puertos abiertos innecesarios o permisos excesivos, puede comprometer la red.

Redes inalámbricas sin cifrar o con cifrados obsoletos.

Una red WiFi insegura es esa conexión inalámbrica mal configurada que deja tus datos expuestos a cualquiera en rango. En casas, oficinas o incluso en Dos Hermanas, muchos usan contraseñas débiles como '123456' o dejan el cifrado por defecto, invitando a vecinos curiosos o hackers a espiar.

-Tipos de cifrado y por qué fallan:

WEP: Roto en minutos; evita a toda costa.
WPA/WPA2: Vulnerable a ataques de diccionario si la clave es débil.
WPA3: El más seguro, pero no todos los dispositivos lo soportan.

Relación entre amenazas y vulnerabilidades

Mecánica de explotación: identificación de vulnerabilidades por los atacantes

La identificación de vulnerabilidades por los atacantes es la fase de reconocimiento e investigación donde buscan fallos, errores de configuración o puntos débiles en un sistema antes de lanzar un ataque.

Fases de identificación de vulnerabilidades:

-Escaneo de redes y puertos: Usan herramientas como Nmap para descubrir qué equipos están conectados y qué puertos o servicios están abiertos.

-Reconocimiento y enumeración: Analizan las versiones exactas del software y los servicios activos mediante programas de análisis o inspección web (como WhatWeb).

-Fuzzing web: Envían datos masivos o aleatorios a las aplicaciones para descubrir directorios ocultos, páginas de acceso o fallos de validación.

-Búsqueda de bases de datos de exploits: Consultan repositorios públicos, bases de datos de vulnerabilidades (CVE) o GitHub para asociar los servicios detectados con códigos de ataque ya existentes.

-Fuentes de la web oscura: Compran información privilegiada, credenciales filtradas o fallos de seguridad de día cero (zero-day) que aún no son públicos

Uso de Exploits y herramientas automatizadas

Usos:



Herramientas:

-WannaCry (2017)

• Herramienta / Vector: Explotó EternalBlue (una vulnerabilidad del protocolo SMB de Windows filtrada por el grupo The Shadow Brokers).

• Impacto: Un ransomware global que afectó a más de 200.000 ordenadores en 150 países, paralizando hospitales, empresas como Telefónica y exigiendo rescates en Bitcoin.

-Stuxnet (2010)

• Herramienta / Vector: Un gusano informático altamente sofisticado diseñado para sabotaje industrial, utilizando múltiples vulnerabilidades de día cero (zero-day) de Windows.

• Impacto: Considerado el primer ciberataque militar real; destruyó cerca del 20% de las centrifugadoras nucleares de Irán en Natanz.
-Colonial Pipeline (2021)
• Herramienta / Vector: El grupo DarkSide utilizó credenciales filtradas y técnicas de extorsión mediante ransomware para acceder a la red corporativa.
• Impacto: Obligó a cerrar temporalmente el mayor oleoducto de combustible en la costa este de Estados Unidos.
-Campaña con Agentes Autónomos de IA (2026)
• Herramienta / Vector: Un atacante utilizó instrucciones cortas coordinando modelos de lenguaje y herramientas como DeepSeek y Claude Code (a través de frameworks como Cairn) para buscar vulnerabilidades en paralelo.
• Impacto: Logró vulnerar o analizar más de 1.200 sitios web y comprometer a más de 100 empresas (incluyendo John Deere, SharkNinja y Cummins) por un costo operativo estimado en unos 5.000 dólares.
-Sony PlayStation Network (2011)
• Herramienta / Vector: Intrusión directa a los servidores mediante vulnerabilidades no parcheadas en la arquitectura de red.
• Impacto: Robó datos de 77 millones de usuarios y mantuvo la plataforma caída durante casi un mes.

Ejemplos prácticos de explotación

• WannaCry (2017): Un ataque masivo de ransomware que cifró cientos de miles de ordenadores en más de 150 países aprovechando una vulnerabilidad de Windows (EternalBlue), afectando a infraestructuras críticas y grandes empresas como Telefónica.
• Stuxnet (2010): Considerado la primera arma digital física, un gusano informático que sabotearon las centrifugadoras del programa nuclear de Irán mediante múltiples vulnerabilidades de día cero.
• Equifax (2017): Una falla de seguridad sin parchar en una aplicación web expuso los datos personales y financieros de más de 147 millones de usuarios.
• Colonial Pipeline (2021): Un ataque de ransomware que paralizó uno de los mayores oleoductos de Estados Unidos tras comprometerse una única contraseña de acceso.

Ransomware en sistemas desactualizados e inyección SQL.

El Ransomware se trata básicamente de un secuestro digital de información en el que bloquean el acceso a tus archivos o a tu dispositivo para luego exigir un pago, conocido como rescate, a cambio de restaurar dicho acceso.

La inyección de SQL es un ataque que manipula ilegalmente una base de datos mediante la inyección de declaraciones no intencionadas de Structured Query Language (SQL) en una aplicación que tiene una base de datos relacional (RDBMS).

Evaluación de las consecuencias de las amenazas y vulnerabilidades.

Impacto sobre la confidencialidad, la integridad y la disponibilidad.

-Impacto sobre la Confidencialidad
-Qué significa: Garantiza que solo las personas o sistemas autorizados puedan acceder a la información.

-Impacto de la amenaza: Robo de datos, espionaje o divulgación no autorizada de secretos comerciales, credenciales y datos personales.

-Ejemplo: Un ataque de phishing o un keylogger que extrae contraseñas corporativas.

-Impacto sobre la Integridad

-Qué significa: Asegura que los datos y los sistemas son exactos, completos y no han sido modificados de forma ilegal o accidental.

-Impacto de la amenaza: Alteración maliciosa de registros, corrupción de bases de datos o inyección de código que hace que la información pierda su fiabilidad.

-Ejemplo: Un ataque de ransomware que cifra o corrompe archivos críticos, o la modificación clandestina de transacciones financieras.

-Impacto sobre la Disponibilidad

-Qué significa: Garantiza que los datos y los servicios están accesibles para los usuarios autorizados en el momento en que se necesitan.

-Impacto de la amenaza: Interrupción total o parcial de los servicios, parálisis operativa y pérdidas económicas graves.

-Ejemplo: Un ataque de denegación de servicio (DDoS) que satura un servidor web e impide el acceso de los clientes

Señales y síntomas de amenazas y vulnerabilidades activas.

Detección de actividad sospechosa en sistemas.

En Actividades Sospechosas, puedes ver las notificaciones generadas por la supervisión del comportamiento de usuarios, dispositivos y redes, basada en la inteligencia artificial de IT Security. Gracias a una red neuronal en constante evolución, esta tecnología aprende de forma autónoma los hábitos del sistema y se adapta dinámicamente al entorno corporativo, detectando sólo las actividades realmente sospechosas y garantizando un análisis de amenazas preciso, personalizado y fiable.

Señales de actividad maliciosa en redes.

1. Escaneo inusual de red desde dispositivos gestionados
Los atacantes intentan mapear la red para detectar posibles objetivos. Si los dispositivos gestionados empiezan a ejecutar escáneres de red sin autorización, es una señal clara de compromiso o mal uso.

2. Presencia de herramientas para desactivar software de seguridad
Algunos dispositivos pueden tener aplicaciones legítimas que permiten desactivar antivirus o firewalls. La gestión centralizada debe detectar y bloquear la instalación o uso no autorizado de estas herramientas para proteger la seguridad del endpoint.

3. Detección de herramientas para robo de credenciales en dispositivos
Herramientas como MimiKatz representan un riesgo enorme, ya que pueden extraer credenciales almacenadas en dispositivos. La administración de endpoints debe monitorear la aparición o ejecución de estas aplicaciones y bloquearlas automáticamente.

4. Patrones repetitivos o anómalos en el comportamiento de los dispositivos
Si ciertos dispositivos presentan actividades inusuales que se repiten a intervalos regulares (por ejemplo, conexiones o procesos desconocidos), puede tratarse de un comportamiento malicioso persistente. La gestión centralizada debe generar alertas ante estos patrones.

5. Intentos de ataques de prueba en endpoints
Los atacantes a veces ejecutan pruebas pequeñas para medir la efectividad de sus ataques y las defensas del sistema. Los dispositivos deben estar configurados para detectar y reportar cualquier intento sospechoso de ejecución de ransomware o malware.

Medidas de protección básicas.

Importancia de las configuraciones seguras en la ciberseguridad.

Conceptos básicos: servicios innecesarios, actualizaciones y vulnerabilidades conocidas.

-Los servicios innecesarios son procesos en segundo plano o funciones de un sistema operativo que no aportan ninguna utilidad al usuario común en un momento dado, pero que consumen recursos de la computadora o representan riesgos de seguridad

-La amenaza por falta de actualizaciones es el riesgo de sufrir ataques informáticos o fallos críticos debido a no instalar los parches de seguridad y mejoras que lanzan los fabricantes.

-Una vulnerabilidad conocida es un fallo, error o debilidad de seguridad en un sistema, software o hardware que ha sido descubierto, documentado y hecho público.

Procedimientos para desactivar servicios innecesarios en sistemas operativos.

-Windows: cuando hayan identificado los servicios de Windows innecesarios, puede deshabilitarlos mediante la herramienta Servicios. Para hacer esto, haga doble clic en el servicio que desea deshabilitar, haga clic en el botón Detener para detener el servicio si se está ejecutando, seleccione Deshabilitado en el menú desplegable Tipo de inicio, haga clic en Aplicar y luego en Aceptar para guardar los cambios. Este proceso debe repetirse para cualquier otro servicio que desee deshabilitar. Alternativamente, se pueden usar métodos más avanzados, como el símbolo del sistema o el Editor del Registro, para deshabilitar los servicios innecesarios de Windows, pero estos métodos requieren más precaución. Para obtener más información sobre cómo usar estos métodos, lo mejor es buscar en línea o en la documentación de Windows.

-Linux/Ubuntu: Este procedimiento permite determinar si se desea que un servicio se inicie o no automáticamente después de iniciado (boot) el sistema operativo.

Los servicios basados en /etc/init.d se manipulan de la siguiente manera.

```
$ sudo update-rc.d NOMBRE_SERVICIO disable   # desactivar
$ sudo update-rc.d NOMBRE_SERVICIO enable    # activar
```

Para desactivar los servicios basados en Upstart se debe editar el archivo /etc/init/NOMBRE_SERVICIO y comentar la linea que empieza con start on. Por ejemplo, para activar el servicio cron se debe realizar el siguiente procedimiento.

```
$ sudo vi /etc/init/cron.conf
# cron – regular background program processing daemon
#
# cron is a standard UNIX program that runs user-specified programs at
# periodic scheduled times
description    “regular background program processing daemon”
# start on runlevel [2345]
stop on runlevel [!2345]
expect fork
respawn
exec cron
```

Para activar nuevamente el servicio será necesario remover el comentario al comienzo de la línea start on.

Herramientas para gestionar actualizaciones y parches de seguridad

Las herramientas de gestión de actualizaciones y parches permiten mantener los sistemas operativos y programas actualizados, corregir vulnerabilidades y proteger los equipos frente a posibles ciberataques.
Principales herramientas
- Windows Update: Actualiza Windows y corrige fallos de seguridad del sistema operativo.
- WSUS (Windows Server Update Services): Permite a las empresas gestionar y distribuir actualizaciones de Windows de forma centralizada.
- Microsoft Intune: Permite administrar dispositivos y controlar las actualizaciones de seguridad.
- SCCM / Microsoft Configuration Manager: Facilita la gestión de actualizaciones, aplicaciones y equipos en organizaciones.
- Ansible: Automatiza la instalación de actualizaciones y parches en servidores.
- Red Hat Satellite: Gestiona actualizaciones y parches de seguridad en sistemas Red Hat Enterprise Linux.
- ManageEngine Patch Manager Plus: Permite detectar, instalar y gestionar parches en diferentes sistemas operativos y aplicaciones.
¿Por qué son importantes?
Estas herramientas ayudan a:
- Corregir vulnerabilidades conocidas.
- Prevenir ataques informáticos.
- Automatizar las actualizaciones.
- Reducir los errores humanos.
- Mantener los sistemas seguros y funcionando correctamente.

Gestión de contraseñas robustas

Es el conjunto de prácticas y medidas que permiten crear, almacenar y utilizar contraseñas seguras para proteger cuentas, dispositivos y sistemas informáticos frente a accesos no autorizados.

Características

- Longitud: Preferiblemente, 15 caracteres o más.
- Imprevisibilidad: Evitar palabras comunes y datos personales.
- Unicidad: Utilizar una contraseña diferente para cada cuenta.
- Almacenamiento seguro: Guardarlas en un gestor de contraseñas fiable.
- Protección adicional: Utilizar autenticación multifactor (MFA).

Políticas de contraseñas

- Exigir contraseñas suficientemente largas y difíciles de adivinar.
- Prohibir contraseñas comunes o previamente comprometidas.
- No reutilizar contraseñas en diferentes servicios.
- Cambiar las contraseñas cuando existan indicios de filtración o robo.
- Limitar los intentos de inicio de sesión para evitar ataques automatizados.
- No compartir las contraseñas con otras personas.

Posibles métodos alternativos

- Autenticación multifactor (MFA): Añade un segundo método de verificación, como una aplicación de autenticación.
- Datos biométricos: Permiten identificarse mediante huellas dactilares o reconocimiento facial.
- Passkeys: Utilizan claves criptográficas para iniciar sesión sin necesidad de una contraseña tradicional.

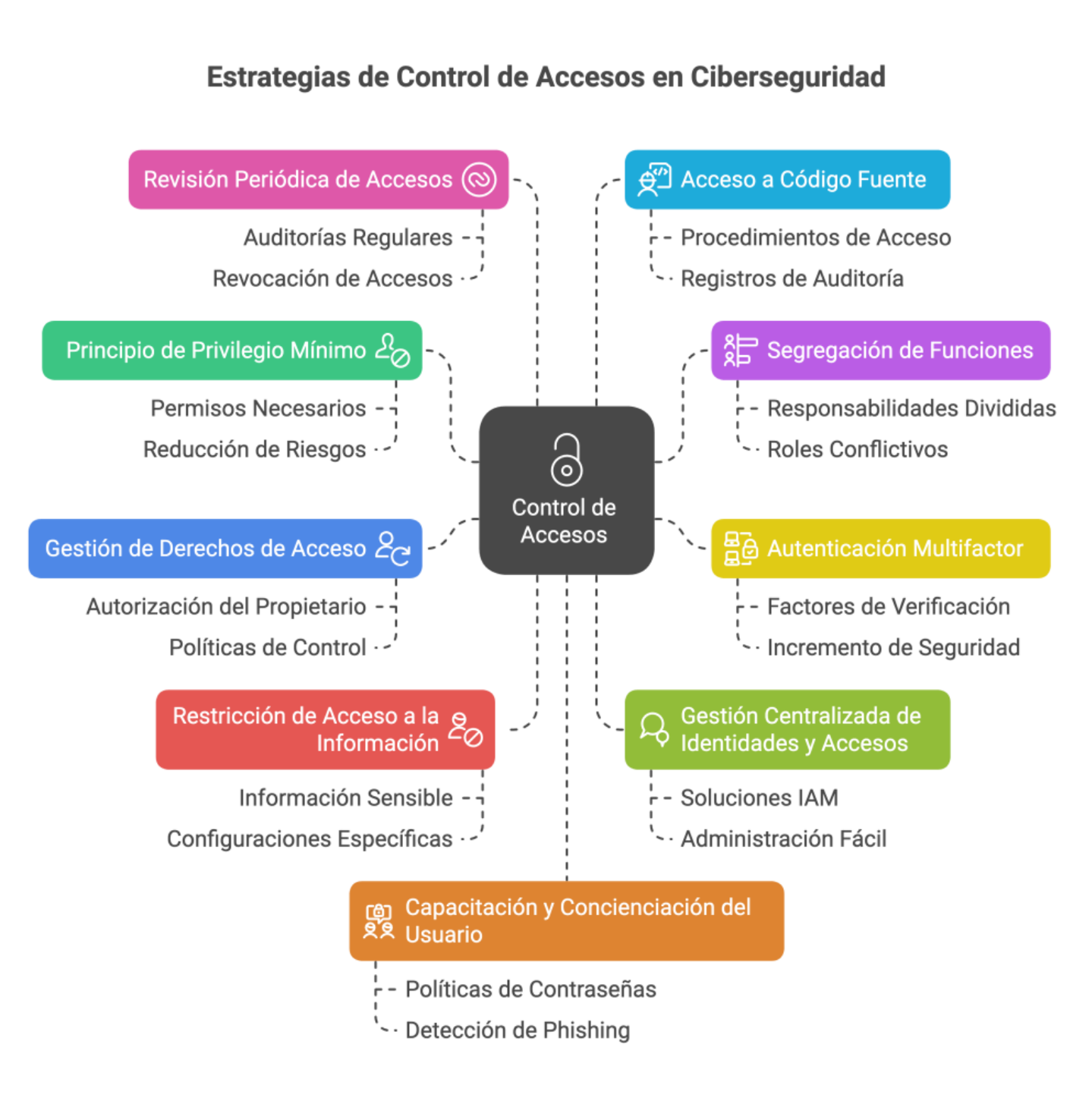
- Llaves de seguridad físicas: Dispositivos que permiten verificar la identidad de forma segura.
- Certificados digitales: Permiten autenticar usuarios o dispositivos mediante certificados criptográficos.

autenticación Multifactor (MFA).

Control de accesos y permisos.

El control de acceso en ciberseguridad se refiere al conjunto de tecnologías, políticas y procedimientos que determinan quién puede entrar, a qué recursos y bajo qué condiciones, dentro de un entorno digital.

Este sistema no solo protege el acceso a archivos o carpetas, sino también a servidores, bases de datos, software corporativo y sistemas críticos. Para implementarlo correctamente, se recomienda seguir normas como la ISO/IEC 27001, que establece requisitos para la gestión de la seguridad de la información.



Principios de control de acceso.

Principios Fundamentales del Control de Acceso
• Principio de menor privilegio: Los usuarios y aplicaciones solo obtienen los permisos mínimos indispensables para realizar sus tareas laborales.
• Separación de funciones: Divide las tareas críticas entre dos o más personas para evitar fraudes, errores o abusos de autoridad.
• Verificación explícita: Se valida de forma continua la identidad, el dispositivo y el contexto en cada solicitud, un concepto clave en arquitecturas de Confianza Cero.
• Responsabilidad y trazabilidad: Cada acción queda registrada en auditorías y logs para identificar al responsable tras cualquier evento de seguridad.
Modelos :

Modelo	Descripción	Enlace de referencia
DAC *(Discrecional)*	El propietario o creador del recurso decide quién tiene acceso a él.	SentinelOne DAC
MAC *(Obligatorio)*	Una autoridad central fija niveles de seguridad estrictos; los usuarios no pueden modificarlos.	Fortinet MAC
RBAC *(Basado en Roles)*	Los permisos se asignan según el puesto o rol del empleado en la empresa.	Red Hat RBAC
ABAC *(Basado en Atributos)*	Evalúa condiciones dinámicas (ubicación, hora, tipo de dispositivo, nivel de riesgo) en tiempo real.	Microsoft ABAC
RuBAC *(Basado en Reglas)*	Aplica reglas generales del sistema (por ejemplo, "ningún usuario accede fuera del horario laboral").	Red Hat RuBAC

Herramientas para gestionar actualizaciones y parches de seguridad.

Análisis de los incidentes de seguridad.

Herramientas y tecnologías de aplicación.

Enlaces

- Tríada CIA
- Ingeniería Social
- XSS
- Ciberseguridad control de acceso